

Vulnerability Assessment Report

Future Interns – Cyber Security Task 1 (2026)

Target Website

<https://demo.testfire.net>

Prepared By

Dency Dasari

Assessment Type

Passive Vulnerability Assessment (Read-Only Scope)

Date

May 2026

Executive Summary

A passive vulnerability assessment was conducted on the public demo website `demo.testfire.net` using OWASP ZAP and browser-based inspection techniques.

The purpose of this assessment was to identify common security weaknesses, insecure configurations, and missing protections without performing any harmful or exploitative actions.

Several security issues were identified during the assessment, including:

- DOM-Based Cross Site Scripting (XSS)
- Missing Anti-CSRF Tokens
- Missing Security Headers
- Mixed Content Issues
- Insecure Cookie Configuration
- Cross-Domain JavaScript Inclusion

The findings indicate that the website contains multiple client-side and configuration-related weaknesses that may increase the risk of attacks such as session hijacking, malicious script injection, clickjacking, and insecure communications.

This assessment was conducted ethically and within a passive, read-only scope.

Scope of Assessment

Allowed Activities

- Public page analysis
- Passive vulnerability scanning
- Security header inspection
- Cookie inspection
- Configuration analysis

Restricted Activities

- Exploitation attempts
- Login bypass
- Brute force attacks
- Denial-of-Service attacks
- Data modification
- Credential attacks

Tools Used

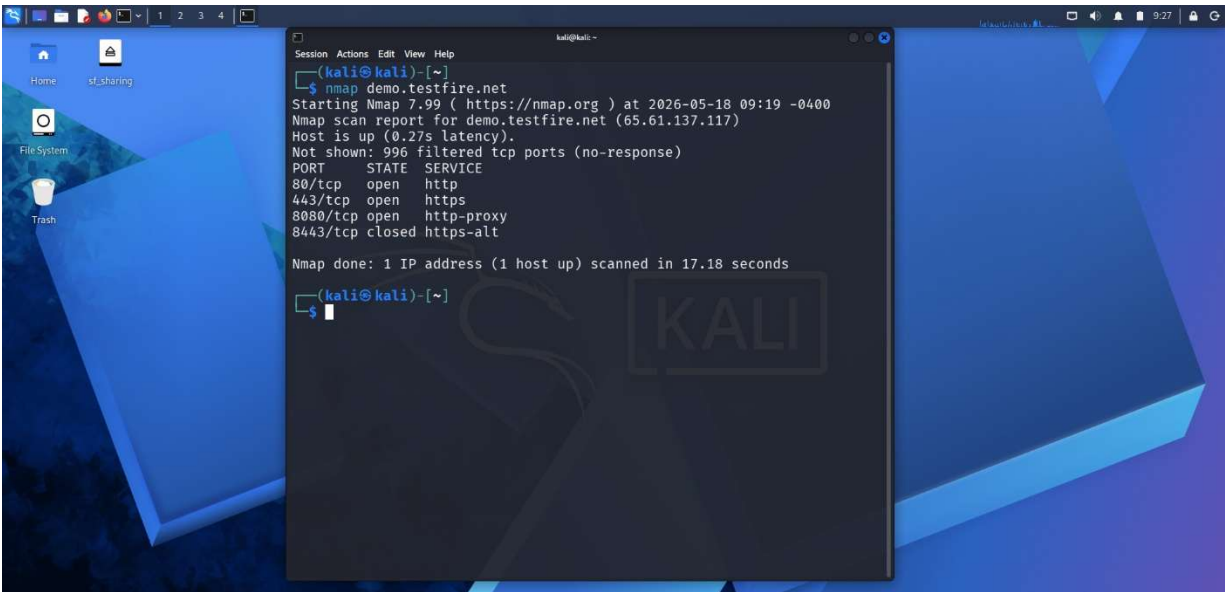
Tool	Purpose
OWASP ZAP	Passive vulnerability scanning
Browser Developer Tools	Header and cookie inspection
Nmap (Optional)	Exposure analysis

Port & Service Analysis (Nmap)

Description:

A basic Nmap scan was performed to identify exposed services.

Evidence:



Observation:

The server exposes standard web ports such as HTTP (80) and HTTPS (443).

Methodology

The assessment followed a passive security testing methodology.

1. The target website was accessed through a web browser.
2. OWASP ZAP passive scanner was used to inspect responses.
3. HTTP headers, cookies, scripts, and content loading behaviour were analyzed.
4. Identified issues were categorized according to risk level.
5. Recommendations were prepared for remediation.

No exploitation or harmful activity was performed.

Risk Rating Scale

Risk Level	Description
High	May directly impact users or application security
Medium	Moderate security weakness requiring remediation
Low	Minor weakness or security best-practice issue

Summary of Findings

Vulnerability	Risk Level
DOM Based Cross Site Scripting (XSS)	High
Absence of Anti-CSRF Tokens	Medium
Content Security Policy (CSP) Header Not Set	Medium
Missing Anti-clickjacking Header	Medium
Secure Pages Include Mixed Content	Medium
Sub Resource Integrity Attribute Missing	Medium
Cookie without SameSite Attribute	Low
Cross-Domain JavaScript Source File Inclusion	Low
HTTPS Content Available via HTTP	Low

Detailed Findings

Finding 1 – DOM Based Cross Site Scripting (XSS)

Risk Level

High

Description

The application appears vulnerable to DOM-based Cross Site Scripting (XSS). The browser processes unsafe user-controlled content, which may allow malicious JavaScript execution.

Impact

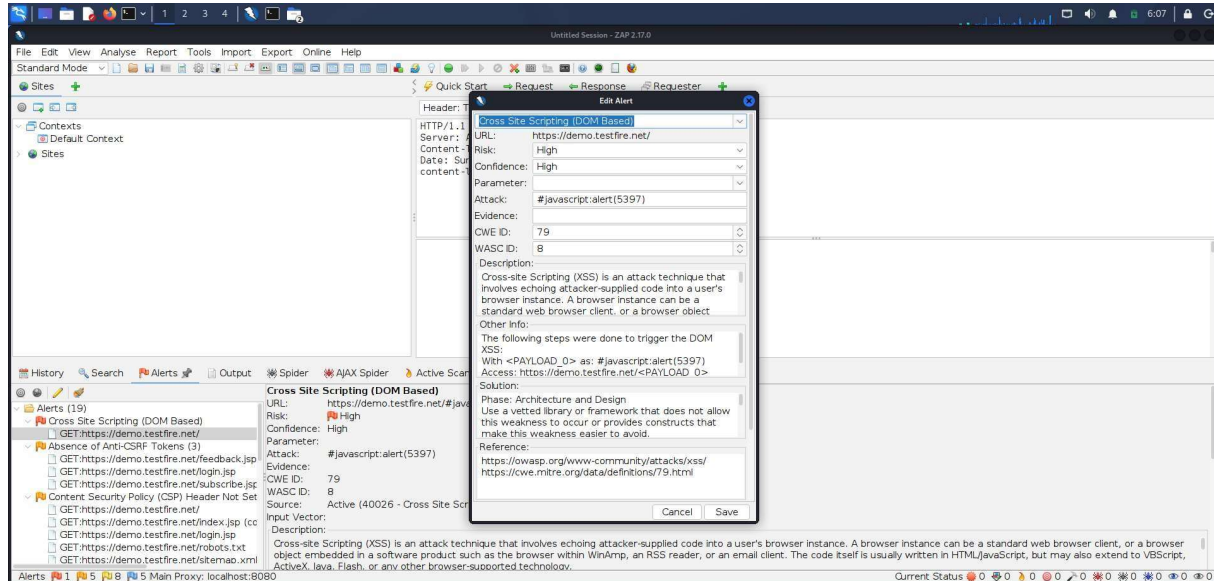
An attacker may inject malicious scripts into the victim's browser, potentially leading to:

- Session hijacking
- Credential the

- Phishing attacks
- Malicious redirects

Evidence

OWASP ZAP identified a DOM-based XSS issue on the target website.



Recommendation

- Validate and sanitize all user input
- Implement output encoding
- Configure Content Security Policy (CSP)
- Avoid unsafe JavaScript functions

Finding 2 – Absence of Anti-CSRF Tokens

Risk Level

Medium

Description

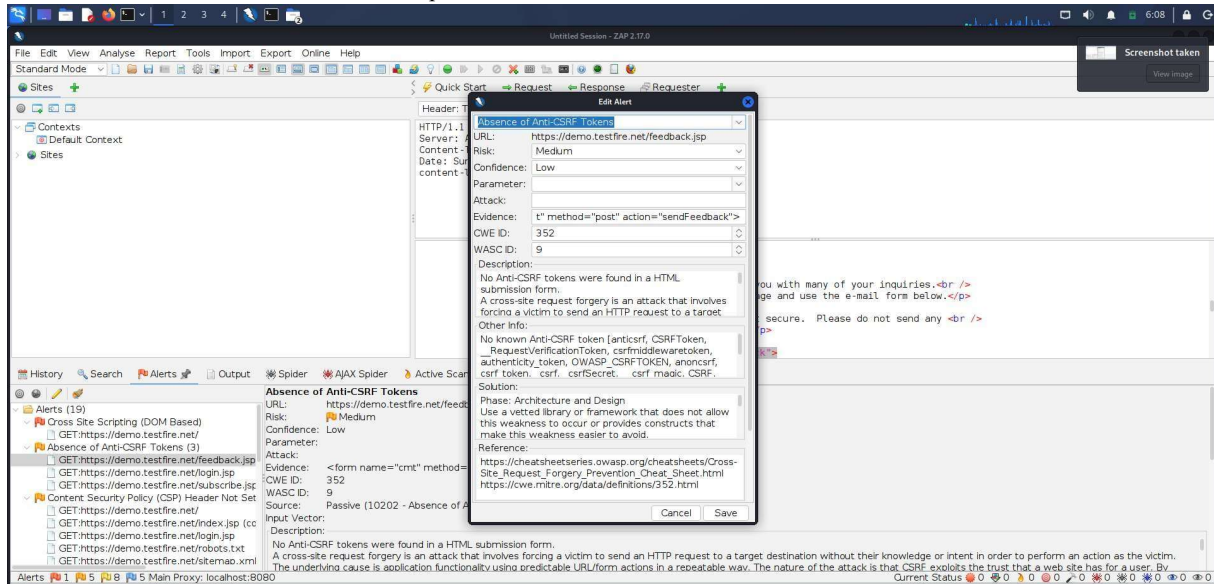
The website contains forms without Anti-CSRF protections.

Impact

Attackers may trick authenticated users into submitting unwanted requests on the application.

Evidence

OWASP ZAP detected forms without CSRF protection tokens.



Recommendation

- Implement CSRF tokens for all sensitive forms
- Validate tokens on the server side
- Use SameSite cookie protections

Finding 3 – Content Security Policy (CSP) Header Not Set

Risk Level

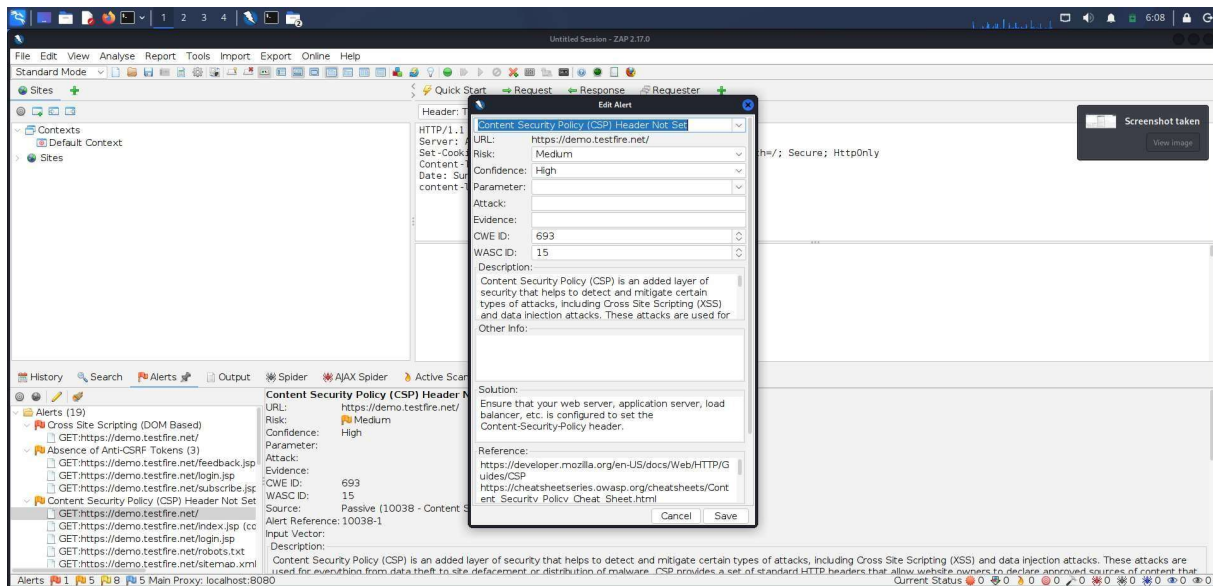
Medium

Description

The application does not define a Content Security Policy (CSP) header.

Impact

Without CSP, the browser has fewer protections against malicious script injection and data injection attacks.



Evidence

The HTTP response headers did not contain a valid Content-Security-Policy header.

Recommendation

Configure a strong Content Security Policy to restrict untrusted scripts and resources.

Finding 4 – Missing Anti-clickjacking Header

Risk Level

Medium

Description

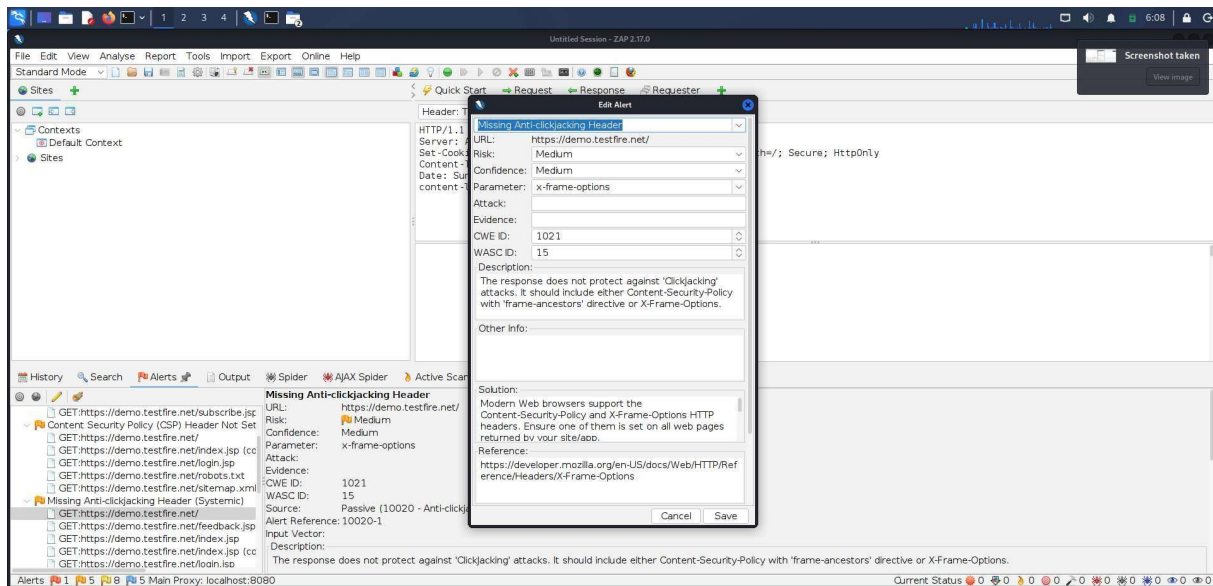
The application does not include anti-clickjacking protections such as X-Frame-Options or CSP frame restrictions.

Impact

Attackers may embed the website inside malicious iframes to trick users into performing unintended actions.

Evidence

The response lacked proper anti-clickjacking security headers.



Recommendation

Implement:

- X-Frame-Options: DENY
- or CSP frame-ancestors directive

Finding 5 – Secure Pages Include Mixed Content

Risk Level

Medium

Description

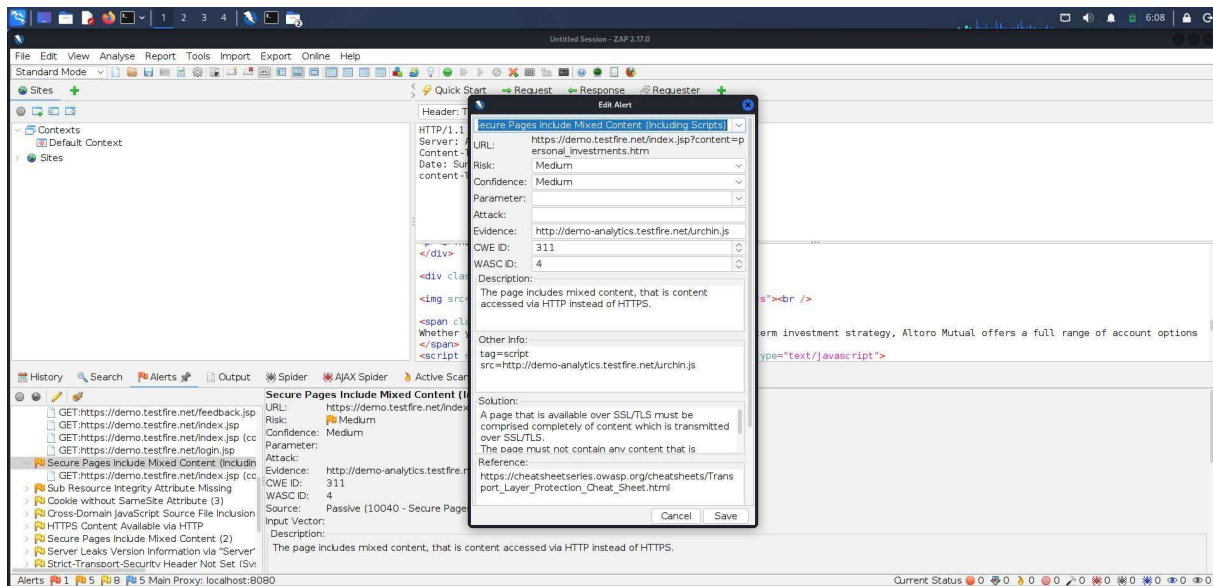
Secure HTTPS pages were found loading resources over insecure HTTP connections.

Impact

Mixed content may allow attackers to intercept or modify insecure resources.

Evidence

OWASP ZAP identified insecure HTTP resources loaded inside HTTPS pages.



Recommendation

- Ensure all resources are loaded using HTTPS
- Remove insecure external references
- Enforce HSTS policy

Finding 6 – Sub Resource Integrity Attribute Missing

Risk Level

Medium

Description

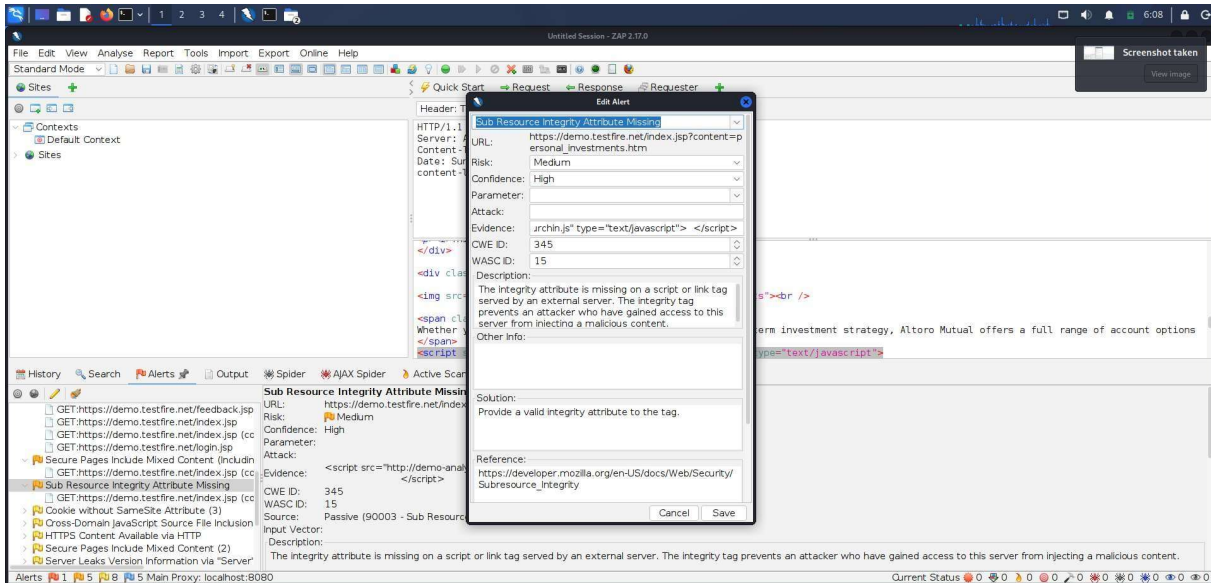
External JavaScript resources were loaded without Subresource Integrity (SRI) validation.

Impact

If the external resource is compromised, malicious scripts may execute within the application.

Evidence

The website included external scripts without integrity attributes.



Recommendation

Use SRI hashes for external scripts and stylesheets.

Finding 7 – Cookie without SameSite Attribute

Risk Level

Low

Description

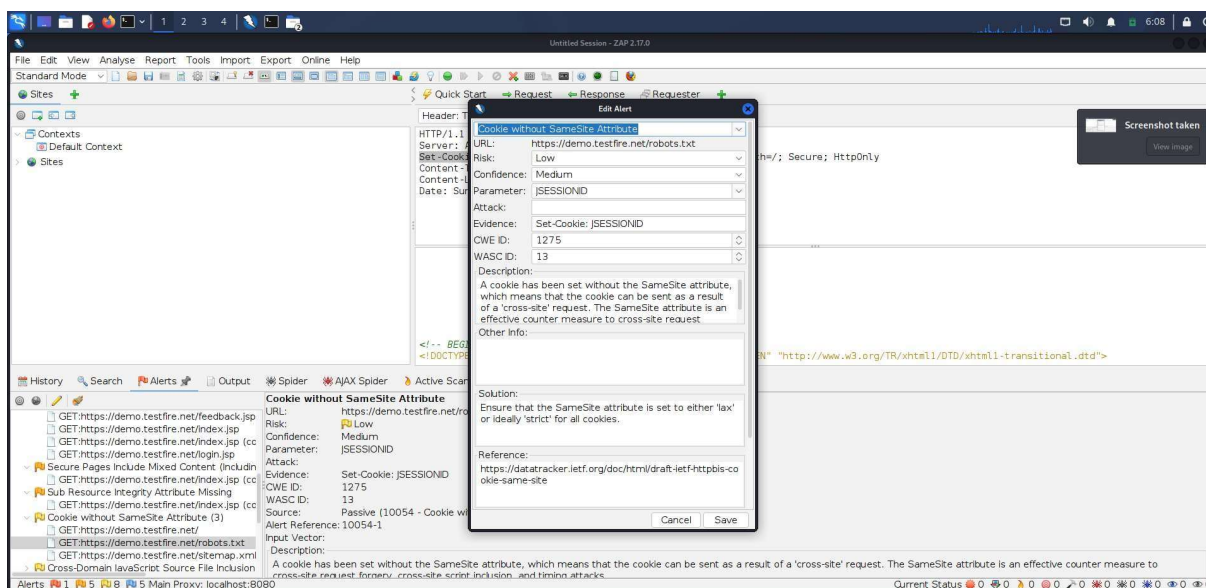
Cookies were set without the SameSite attribute.

Impact

Cookies may be included in cross-site requests, increasing CSRF-related risks.

Evidence

OWASP ZAP identified cookies without SameSite protections.



Recommendation

Configure cookies with:

- SameSite=Lax
- or SameSite=Strict

Finding 8 – Cross-Domain JavaScript Source File Inclusion

Risk Level

Low

Description

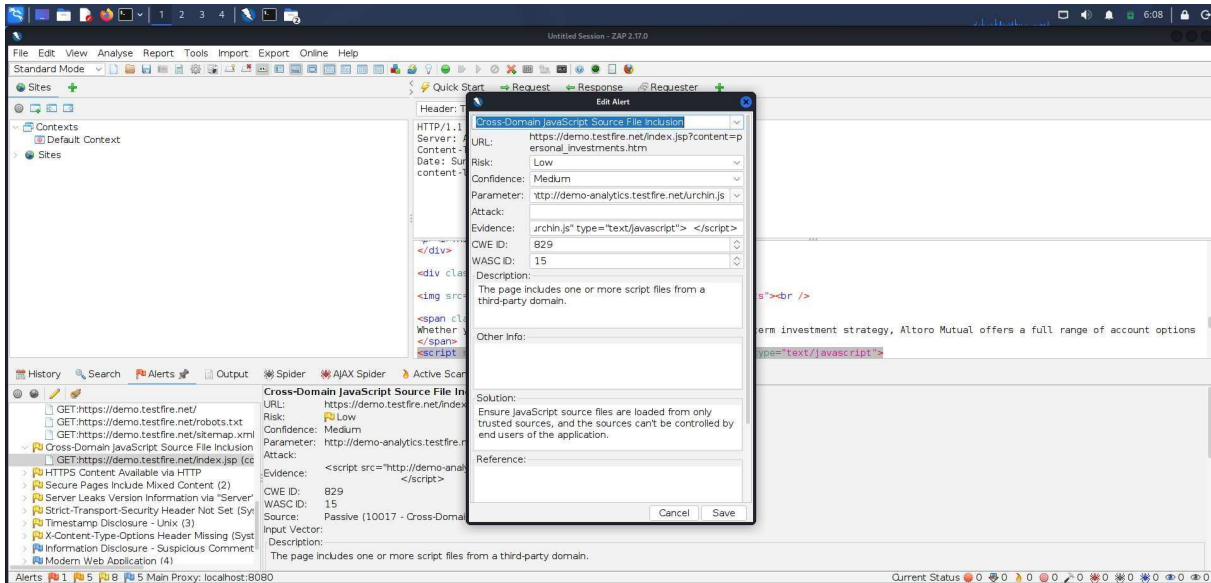
The application loads JavaScript from third-party domains.

Impact

If the external source becomes compromised, malicious code may be delivered to users.

Evidence

Cross-domain JavaScript inclusion was detected.



Recommendation

- Use trusted sources only
- Apply Subresource Integrity (SRI)
- Minimize third-party scripts

Finding 9 – HTTPS Content Available via HTTP

Risk Level

Low

Description

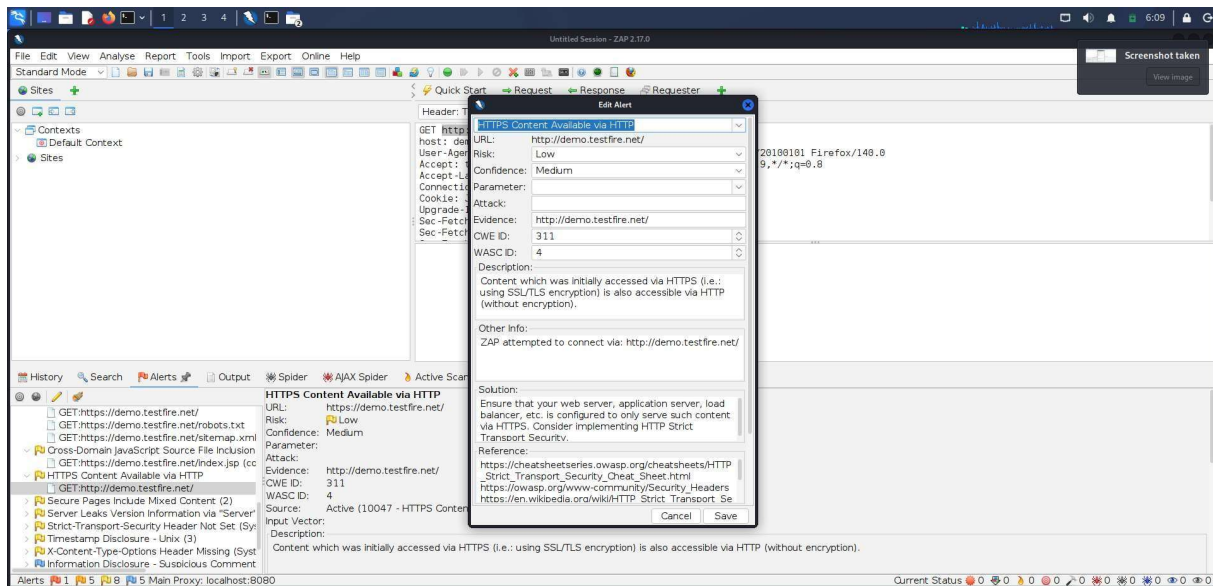
Content accessible through HTTPS was also accessible via insecure HTTP.

Impact

Users accessing the HTTP version may be exposed to unencrypted communications.

Evidence

OWASP ZAP successfully accessed content over HTTP.



Recommendation

- Redirect all HTTP traffic to HTTPS
- Enable HSTS (HTTP Strict Transport Security)

Overall Recommendations

The following actions are recommended to improve the website's security posture:

1. Implement strong input validation and output encoding
2. Configure modern security headers
3. Enforce HTTPS across the application
4. Remove mixed content
5. Use secure cookie configurations
6. Apply Subresource Integrity for third-party resources
7. Regularly perform vulnerability assessments
8. Keep frameworks and dependencies updated

Conclusion

The passive security assessment identified several security weaknesses and configuration issues within the target application.

Although no exploitation was performed, the identified findings demonstrate areas where security controls can be improved to reduce potential attack risks.

This assessment was conducted ethically for educational and awareness purposes only.

Disclaimer

This report was prepared as part of an educational cybersecurity internship task.

The assessment was limited to passive analysis and publicly accessible content only.

No harmful actions, exploitation attempts, or unauthorized access activities were performed during testing.